Security

Keamanan => melindungi kerahasiaan, integritas, dan ketersediaan di tengah ancaman dan bencana

Konsep keamanan
- → Kerahasiaan
- → Integritas data / keutuhan data
- → Ketersediaan
- → Otentikasi
- → Otorisasi
- → Akuntabilitas
- → Non-repudiation

Kerentanan (vulnerability) => Kelemahan sistem keamanan

Ancaman (threat) => Hampiran sistem yang berpotensi kerugian atau kerusakan.

Ancaman =
- # Interception (sadap)
- # Interruption (matut)
- # Modification (ubah)
- # Fabrication (palsu)

Attack
- # Injection => using valid fields to enter a dangerous code
  - ↳ SQL injection
  - ↳ SQL poisoning
- # Cross-Site Scripting => using JS to steal information by displaying in the browser (false valid field)
- # Session Hijacking => steal the cookies to authenticate as user.
- # Denial of Service => Block the access for the service. e.g. DDoS
- # Brute force

How to prevent it?
- # Prevent it (cegah)
- # Deter it (halangi)
- # Deflect it (belok)
- # Detect it (deteksi)
- # Recover it (pulihkan)

Auth => Process to ensuring that a user of a system is who they claim by.
↳ Process of claiming.

Authentication vs Authorization

Authorization is a process of proving the identity of a user to the system
↳ e.g. is this authorization to read a folder

Encryption ⇒ is the process of making a document unreadable by applying an algorithmic transformation to it
↳ Symmetric VS Asymmetric encryption.

Privacy ⇒ is a social concept that relates to the collection, dissemination, and appropriate use of personal information held by third party such as a company or a hospital.

Data Protection Principles
- ↳ Anonymity & Control
- ↳ Purpose
- ↳ Consent
- ↳ Data lifetime
- ↳ Secure Storage
- ↳ Discovery & error correction
- ↳ Location.

Keep Security Simple

Service Oriented Software Engineering

Service ⇒ ~~Potong~~ Tindakan / pelaksanaan yg ditawarkan oleh satu pihak ke pihak lain.
- ↳ Loosely coupled.
- ↳ Independent thdp behavior.
- ↳ Reusable Component.

SOA ⇒ Cara pengembangan sistem terdistribusi dimana komponen merupakan service yang berdiri sendiri

↳ Advantages :
- # Lokal / out sourcing
- # Independent
- # Legacy
- ~~# Complex~~

Standar kunci :
- # SOAP (Simple Object Access Protocol)
- # WSDL (Web service definition language)
- # WS-BPEL (Web Services – Business Process Execution Language)

WSDL
- Intro → HTML namespace declaration, Type declaration
- Abstract Interface → Interface declaration, Message declaration
- Concrete Implementation → Binding declaration, Endpoint declaration.

~~RE~~ ~~REST~~

RESTful web
↳ Representational State Transfer
↳ Community used.

Disadvantages :
- # No Standard
- # Linear complexity.
- # Need monitoring.

Interface Design Stages
Logical interface design → Operation, input, output, exceptions
Message design (SOAP) ⇒ UML
Interface design (REST)

Design Performance

Performance engineering → Proyek harus diuji dan disesuai ul tujuan → dikoreksi

↳ kategori : # ~~[illegible]~~ Kecepatan
Skalabilitas
Stabilitas.

prinsip → deskripsi kinerja sistem → # Linearitas
keandalan
kemudahan pengelola
kemudahan pemakaian
kendalitasi
Independensi.

Tujuan skalabilitas → Performance (kinerja)
→ Ketersediaan
↳ Maintainability

Tipe skalabilitas → Load scalability
→ Space scalability
→ space-time scalability
↳ Structural scalability

Perancangan performance web apa: ✓# Skalabilitas → Load scalability, Space scalability, space-time scalability, Structural scalability.
✓# Pengujian
✓# Observability ⇒ Log metrics.

Analisis dan Perancangan Web

A service can be defined as a loosely-coupled, reusable, software component that encapsulated discrete functionality which may be distributed and programmatically accessed.

Analisis → Konten
→ Interaksi
→ Fungsional (use case)
→ Konfigurasi

Component design (Architecture) → Architecture design → Navigation design → Content design → Aesthetic design → Interface design → (cyc)

Interface Design Principles:
Anticipation
Communication
Consistency
Controlled autonomy
Efficiency
Focus
Fitt's law
Human interface objects.
Latency reduction
Learnability
Readability
Trade state
Visible navigation.

Interaction Model
Use case
Sequence diagrams
State diagrams
UI prototypes

Configuration Model → Server side
→ Client side.

Perancangan Perangkat Lunak

Kriteria evaluasi Metode Desain Modular :

Modular Decomposability
Modular composability
Modular understandability
Modular continuity
Modular protection.

Cohesion
- → Coincidental => "kebetulan"
- → Logical => "logika", "algoritma"
- → Temporal => "tujuan sementara tetapi berhubungan"
- → Communicational =>
- → Functional => sulit terdefinisi dengan jelas.

Information Hiding
- → Mengurangi lingkup efek samping.
- → Menerapkan komunikasi
- → Mengurangi penerima data global
- → encapsulation.

How we can reduce risk?

Minimize attack surface area.
Secure by default
Least privileged
Defense in depth.